

Gateway, Swagger ve Platform Güvenliği

Topoloji

```
Client
-> FinWallet.Gateway :8080
  -> FinWallet.Api :8081
    -> Gateway /providers/bank/* -> FakeBank.Api :8082
    -> Gateway /providers/fraud/* -> FakeFraud.Api :8083
    -> Gateway /providers/cutoff/* -> FakeCutoff.Api :8084
    -> Gateway /providers/campaign/* -> FakeCampaign.Api :8085
    -> Gateway /providers/communication/* -> FakeCommunication.Api :8086
```

FinWallet provider simulatorlarını doğrudan çağırmaz; provider base URL'leri Gateway'e döner.

Customer authentication boundary

Gateway'de anonymous route'lar yalnız register/verify/login/refresh'tir. Diğer /api/* route'ları GatewayAuthenticated policy ile JWT ister. FinWallet.Api JWT ve business ownership kontrolünü tekrar yapar.

Internal provider boundary

FinWallet.Api /providers/* için X-Internal-Service-Key gönderir. Gateway InternalService policy ile doğrular ve proxied request'e ayrı DownstreamServiceKey yazar. Destination business endpoint downstream key olmadan 401 döner.

Bu iki ayrı trust boundary sağlar:

- 1 FinWallet -> Gateway;
- 2 Gateway -> destination.

YARP route/load balancing

Cluster config'i appsettings'tedir. PowerOfTwoChoices, destination address, health interval/timeout, passive reactivation, max connections ve activity timeout source code değiştirmeden override edilebilir. Development tek destination içerebilir; production replica ekleyebilir.

Rate limit / resource exhaustion

Repository seviyesinde:

- Gateway per-IP fixed-window rate limit;
- backend second-layer rate limit;
- queue default 0;
- request body/header count/header bytes limit;
- request-header/keep-alive timeout;
- max concurrent connections;
- provider-specific YARP body limits;
- provider HttpClient timeout/connection limits.

Bu L7 overload/abuse korumasıdır. Volumetric DDoS için cloud DDoS protection, L4/L7 LB, WAF/CDN/bot protection ve network policy gerekir.

Swagger

Swagger şu projelerde ortak FinWallet.Shared.Web ile vardır:

- Gateway;
- FinWallet.Api;
- FakeBank;
- FakeFraud;
- FakeCutoff;
- FakeCampaign;
- FakeCommunication.

Development'da açık, production'da varsayılan kapalıdır. Swagger görünürlüğü endpoint authorization'ı bypass etmez.

Shared HTTP security baseline

- Kestrel Server header off;
- TRACE/CONNECT blocked;
- JSON write content enforcement;
- correlation ID validation/regeneration;
- Cache-Control: no-store;
- X-Content-Type-Options: nosniff;
- X-Frame-Options: DENY;
- restrictive Referrer/Permissions/Cross-Origin policies;
- CSP;
- CORS allow-list;
- rate limiting;
- request/header/body/connection bounds.

OWASP/API mapping

****Broken Access Control/BOLA:**** Gateway+API JWT, owner-aware SQL, server-derived sub/sid, internal provider credentials.

****Security Misconfiguration:**** prod Swagger off, bounded HTTP config, no server header, separate env config.

****Supply Chain:**** central NuGet versions, explicit packages, CI restore/build/test. SBOM/vulnerability scan açık iştir.

****Cryptography:**** PBKDF2, salts, HMAC OTP, short JWT, secret-store, no credential logging.

****Injection:**** parameterized SQL, typed DTO, user-controlled SQL fragment yok.

****Sensitive Business Flows:**** double-entry, durable idempotency, server-side fraud, fail-closed provider behavior.

****Authentication Failures:**** JWT+session+refresh rotation+lockout+OTP+rate limit.

****Integrity Failures:**** DB constraints, append-only/reversal model, atomic posting.

****Resource Consumption:**** layered rate/body/header/connection/time limits.

****SSRF/Unsafe API:**** provider URLs server-owned config; external result provider adapter/validation arkasındadır.

Configuration modeli

Standard .NET precedence:

- 1 appsettings.json;
- 2 appsettings.{Environment}.json;
- 3 environment variables / secret injection;
- 4 ilerde eklenen explicit providerlar.

Network/pool/timeout/rate gibi operasyonel değerler config'tir. Crypto algorithm, double-entry invariant ve persistence semantics runtime switch değildir.